NON-HUMAN IDENTITY LAB

I tested 27 machine identity cases. My guesses were wrong in two places.

Service accounts, API keys, CI tokens, break-glass accounts and AI tools with their own logins. Made-up data, guesses committed before the code, and every control switched off once to see if anything noticed.



Roshan Trivedi | November 2026
roshantrivedi.co.in/nhi-lab/

About this book

Title. I tested 27 machine identity cases. My guesses were wrong in two places.
Edition. 1.0, 2 November 2026. Free to read and share; please credit the author.
Author. Roshan Trivedi, identity and privileged access, Bengaluru. roshantrivedi.co.in

Description

A short lab notebook. It takes 27 situations in which a machine identity (a service account, an API key, a CI token, a break-glass account, an AI tool with its own login) can go wrong. For each one it records what I expected, what a small model of the control did with the control off and on, and whether anything noticed when I switched the control off by itself.

Problem statement

Most companies have many more machine identities than people. Control mapping sheets say a control exists. They rarely show where it stops. Reports from 2026 describe breaches that began with a forgotten token, a leaked secret or an AI app that an employee linked with broad access. Nobody checks whether the usual controls would have held, and people seldom publish their own wrong guesses.

Scope

In scope: 27 cases in six areas: discovering identities, giving them owners and retiring them, credentials and rotation, the front door and trust, privileged access, and shadow AI. Plus three cases from a search for gaps.
Out of scope: any commercial product, real vaults or directories, real cloud tenants, real AI models, cost, and Indian regulation (RBI, CERT-In, data protection). I make no compliance claim.
Second run: 13 stretch cases and 6 chain tests, with their guesses committed first (page 20). The headline numbers in this book are the first 27 cases.

All people, companies, numbers and data are made up. The company, Kaveri Finance, does not exist. Every secret in the tests is fake. This is not a product review and not legal advice. A pass shows the model did what I wrote it to do.

Contents

1 At a glance

2 The method and the workflow

3 All 27 cases

4 Where the market is

5 What is missing, and what to ask

6 Evidence you can check

A Appendix A: case index

B Appendix B: how to re-run the lab

C Appendix C: sources

D Glossary

E About the author

At a glance

27	25	2	2
cases	guesses matched	guesses wrong	controls masked

What, why, how

What. I ran 27 cases about machine identities: finding them, giving them owners, rotating their secrets, controlling privileged access and catching AI tools that quietly hold credentials. 24 were my must-run cases. 3 more came from a search for gaps, based on 2026 incident reports.

Why. Most companies have many more machine identities than people, and mapping sheets say a control exists without showing it holds. I wanted to see where a control stops, and to keep my own wrong guesses on the page.

How. Before any code, I wrote what I expected and committed the files. Then I wrote small models of each control and ran every case with the control off and on. Then I switched each control off by itself to see whether the result changed.

What I found

The secret scan missed two of eight fake secrets, not one. It caught six. The two it missed were a secret split across two lines and a base64-encoded one. I had guessed one miss.

Two controls showed no effect on their own, because another control already stopped the attack. A 10-minute token lifetime changed nothing once the token was bound to the runner and revoked at job end. A vendor-breach revoke changed nothing once an app allowlist refused the grant. That is layering, and it also means a one-at-a-time switch-off can say "nothing happened" for a control that matters in a different scenario.

Several controls stopped where I expected. A made-up ticket number passed the break-glass review because nothing checks it against the ticket system. A false justification for break-glass use was accepted. A bound CI token still worked from inside the runner. An allowlisted app that is later breached works until someone revokes it. A false retirement sign-off left one identity active. A consumer missing from the list still broke after rotation.

One limit up front: I wrote both the guesses and the code, and every case is a small in-memory model, not a real vault, directory or cloud. A match proves little. The misses and the limits are the useful part.

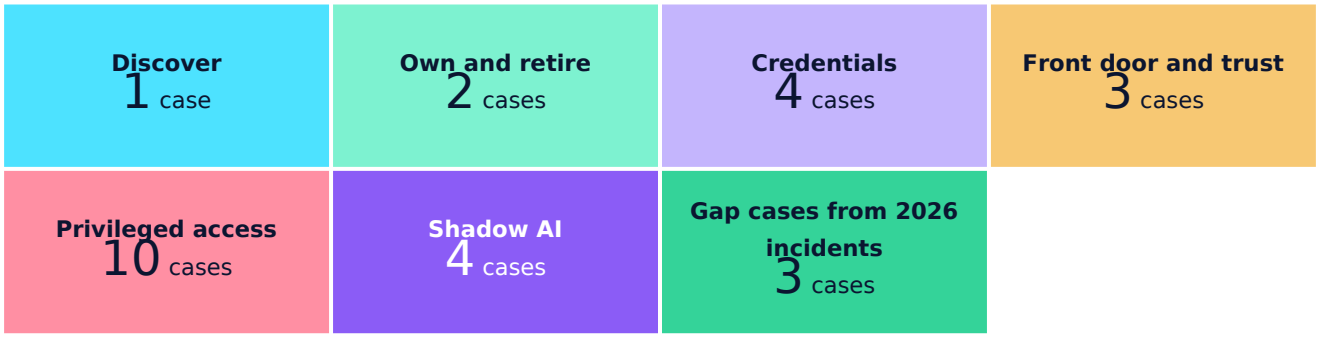
The method

The commit in step 3 is what makes the guesses honest: they cannot change after the result is known.

1	**Write the guess**
2	**Hash it (SHA-256)**
3	**Commit it**
4	**Write the code**
5	**Run it, control on and off**
6	**Switch each control off alone**
7	**Record every miss**

The life of a machine identity

Every case sits on one stage of this loop: discover, own, credential, control, privileged access, retire. Retiring what is unused feeds the next discovery scan.



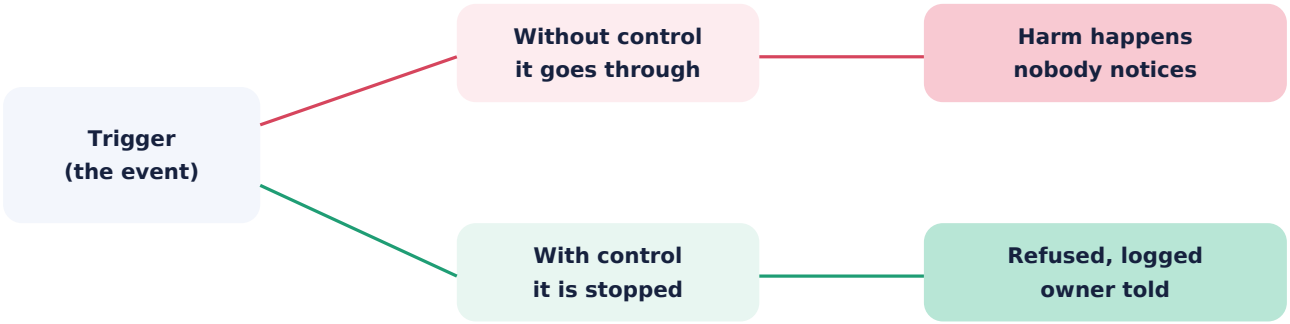


What you retire is gone from the next discovery scan. The loop closes.

The 3 gap cases (OAuth, environment variables, CI runner) sit across several stages.

The workflow of one case

Every one of the 27 cases follows the same path. A trigger happens. Without the control it goes through. With the control it is stopped. Then the control is switched off by itself to see whether anything notices.



Then I switch the control off alone. If nothing notices, another control was already doing the job.

All 27 cases

Each card shows one case. Red is what happens without the control, green is what happens with it. The last line says whether my guess matched and whether switching the control off alone changed the result.

N-R14-01 Inventory misses a source | Discover	
TRIGGER	Three places hold service accounts
WITHOUT	Directory-only scan finds 12 of 27
WITH	All three sources merged: 27 of 27, each with its source
RESULT	Guess matched.

N-R14-03 Long-lived CI variable read by another job | Front door and trust	
TRIGGER	Another job reads a 400-day-old CI key
WITHOUT	The other job reads it. Log says only "pipeline"
WITH	Per-job credential: refused, log names the job
RESULT	Guess matched.

N-R14-04 Certificate with no owner expires | Credentials	
TRIGGER	A certificate with no owner expires
WITHOUT	No warning, outage, someone switches a check off
WITH	Owner warned at 30 and 7 days, no outage
RESULT	Guess matched.

N-R14-05 Old OAuth grant, vendor breached | Credentials	
TRIGGER	Vendor tokens stolen; grant is 14 months old
WITHOUT	Replayed token still reads mail
WITH	Grant had expired at 90 days: refused
RESULT	Guess matched.

N-R14-09 Identity with no owner | Own and retire	
TRIGGER	A key with no named owner
WITHOUT	Still active on day 31
WITH	Paused on day 31
RESULT	Guess matched.

N-R14-11 Application retired, identities remain | Own and retire	
TRIGGER	App retired, its identities stay
WITHOUT	All 3 still work 90 days later
WITH	All 3 disabled, ticket recorded
RESULT	Guess matched. Limit found: attestation signed against an incomplete list.

N-R14-14 Rotation fails silently | Credentials	
TRIGGER	Rotation job fails for 60 days
WITHOUT	Nobody knows; password 60 days stale
WITH	Alert on day 1, score rises weekly
RESULT	Guess matched.

N-R14-15 Rotate before consumer is updated | Credentials	
TRIGGER	Password rotated before the app is updated
WITHOUT	The application fails at next connection
WITH	Consumer first, then rotate, old secret verified dead
RESULT	Guess matched. Limit found: a consumer missing from the list still fails after rotation.

N-R14-17 Loose federation trust | Front door and trust	
TRIGGER	Low-value workload asks for a high-value role
WITHOUT	Gets the role
WITH	Trust bound to one workload: refused
RESULT	Guess matched.

N-R14-18 Front door for new identities | Front door and trust	
TRIGGER	New service account, no owner, scope or expiry
WITHOUT	Created and active
WITH	Refused, with the reason
RESULT	Guess matched.

P-R15-02 Just-in-time window | Privileged access	
TRIGGER	Engineer needs 2 hours on one database
WITHOUT	Access stays after the work
WITH	Closes by itself, credential rotated
RESULT	Guess matched.

P-R15-03 Work runs past the window | Privileged access	
TRIGGER	The job needs 90 more minutes
WITHOUT	Extended again and again: 10 hours
WITH	One extension, then a person must approve
RESULT	Guess matched.

P-R15-05 Standing admin group membership | Privileged access	
TRIGGER	Admin group of 40, 8 did privileged work
WITHOUT	All 40 keep access
WITH	32 removed, 8 remain
RESULT	Guess matched. Limit found: 2 of the 8 who remain have broader access than the work needed.

P-R15-07 Direct login still open | Privileged access	
TRIGGER	Engineer signs in directly with an old password
WITHOUT	Login works, nothing recorded
WITH	Blocked at the network
RESULT	Guess matched.

P-R15-08 Recording gap on one target | Privileged access	
TRIGGER	Nine of ten targets are recorded
WITHOUT	Nobody knows about the tenth
WITH	Tenth found and blocked
RESULT	Guess matched.

P-R15-09 Two approvers for Tier 0 | Privileged access	
TRIGGER	Change to the identity system, one approver
WITHOUT	Runs
WITH	Waits for a second, different person
RESULT	Guess matched.

P-R15-11 Break-glass used at 2 a.m. | Privileged access	
TRIGGER	Break-glass account used at 2 a.m.
WITHOUT	Unnoticed, password unchanged
WITH	Alert fires, password rotated
RESULT	Guess matched. Limit found: the text is not checked for truth.

P-R15-13 Break-glass becomes a side door | Privileged access	
TRIGGER	Break-glass used for routine work, 4 days
WITHOUT	No one notices
WITH	2 uses with no ticket flagged
RESULT	Guess matched. Limit found: a ticket number is not checked against the ticket system.

P-R15-17 Vendor session | Privileged access	
TRIGGER	Vendor engineer connects for 4 hours
WITHOUT	No record, access stays
WITH	Recorded and closed at 4 hours
RESULT	Guess matched.

P-R15-18 Vendor person leaves the vendor | Privileged access	
TRIGGER	Vendor person leaves their company
WITHOUT	Account still active at 120 days
WITH	Disabled at the next 30-day review
RESULT	Guess matched.

S-R17-01 Personal OAuth grant to an AI tool | Shadow AI	
TRIGGER	Employee grants an AI tool access, then leaves
WITHOUT	Grant keeps working
WITH	Found and revoked; ownerless grants refused
RESULT	Guess matched.

S-R17-03 Agent runs under a person's account | Shadow AI	
TRIGGER	An automation uses a person's login
WITHOUT	Log cannot tell human from agent
WITH	Agent has its own identity and log tag
RESULT	Guess matched.

S-R17-04 Ghost credential | Shadow AI	
TRIGGER	AI workflow makes a key with no owner
WITHOUT	Key stays valid forever
WITH	Refused at creation; sweep disables expired keys
RESULT	Guess matched.

S-R17-05 Secrets in AI-assisted code and config | Shadow AI	
TRIGGER	AI-written code and MCP config hold secrets
WITHOUT	All 8 fake secrets reach the repository
WITH	6 of 8 blocked; 2 get through
RESULT	Guess wrong: 2 misses, not 1. Misses: a secret split across two lines and a base64-encoded one.

N-R14-23 Vendor breached, OAuth refresh token still valid | Gap cases from 2026 incidents	
TRIGGER	Vendor breached; refresh token still valid
WITHOUT	Grant accepted, replay reads files
WITH	Allowlist refuses the grant; revoke ends replays after 60 minutes
RESULT	Guess matched. The vendor-breach revoke showed no effect alone, because the allowlist already refused the grant. Limit found: an allowlisted app that is breached still works until revoked.

N-R14-24 Secrets in env variables not marked sensitive | Gap cases from 2026 incidents	
TRIGGER	Secrets in environment variables not marked sensitive
WITHOUT	2 secrets readable in plain text
WITH	3 of 4 hidden; 1 odd one missed
RESULT	Guess matched.

N-R14-25 Credential stolen from a CI runner, replayed | Gap cases from 2026 incidents	
TRIGGER	Token copied from a CI runner, replayed
WITHOUT	Both replays work
WITH	Both replays refused
RESULT	Control-off guess wrong: the short lifetime was masked by binding and revoke. The 10-minute lifetime showed no effect alone. Limit found: bound token still works from inside the runner during the job.

Where the market is

I did not test any commercial product. This is how I read the categories, from public sources. Check each vendor's own documentation for what a product does today.

PAM vaults and brokers

CyberArk, Delinea, BeyondTrust and others. Strong at vaulting and rotating privileged and service-account passwords, session recording and just-in-time access. In my cases: rotation, JIT windows, recording and break-glass.

IGA

SailPoint, Saviynt and others. Built for owners, certification campaigns and joiner-mover-leaver. In my cases: ownership, retirement and sponsor reviews.

Secrets managers

HashiCorp Vault and the cloud secret managers. Store and issue secrets, often short-lived. In my cases: short token lifetimes and per-job credentials.

NHI-focused and cloud-risk platforms

Clutch, Wiz and similar. Newer products aimed at finding machine identities and their relationships across cloud, CI and SaaS. In my cases: discovery and the OAuth and CI paths.

What the sources say

OWASP publishes a Top 10 for non-human identities (2025), with ten named risks including improper offboarding and human use of non-human identities. OWASP's agentic applications list for 2026 covers identity and privilege abuse, code execution, memory poisoning and inter-agent communication; I read a summary by Teleport, so check the OWASP original before quoting.

Tuhin Banerjee argues on the CSA blog (23 April 2026) that inventory-first discovery is losing ground to ephemeral identities, and that ownership and fast revocation are the neglected parts. It is an opinion piece built on named incidents, with no survey data.

Vercel confirmed unauthorized access in April 2026. Reports say it began with a third-party AI app that an employee had linked with broad permissions. Attribution and some details are unverified (I read a summary by Strapi).

GitGuardian's 2026 report (vendor research, 2025 data) counts 28,649,024 new secrets on public GitHub, 1,275,105 of them AI-service secrets, and 24,008 unique secrets in MCP configuration files. Quote with the name. NIST's NCCoE published a concept paper on software and AI agent identity and authorization on 5 February 2026; it is a concept paper only.

What is missing

In the market, as I see it (my view)

- Checks that a sign-off is true. Owner attestations, break-glass justifications and ticket numbers are accepted as text in my models, and I suspect many real workflows are the same.
- Speed of revocation across companies. When a vendor is breached, the clock starts at their notice, not your inventory.
- Ephemeral identities that live for minutes. An inventory taken weekly cannot see them.
- One place that shows the agent, the person who set it up and the permissions it inherited.

In this lab

- It is a model, not a real environment. Real vaults, directories and CI systems will behave differently.
- I wrote both the guesses and the code. An outside reader writing guesses first would be a stronger test.
- The 13 stretch cases and 6 chain tests ran in a second run. 21 queued cases and the Stage 2 testing are not run.
- AWS, Azure and Google Cloud each have their own key and role habits. These cases are generic.
- Indian rules (RBI, CERT-In, data protection) are not checked. I make no compliance claim.
- No cost data.

How this helps, and five questions to ask

I work in identity and privileged access, and I publish the tests with the mistakes so readers can see how I think. If you run security or identity at a company, these are the questions the lab turns into:

1. Can you list every service account across the directory, the cloud and CI, and does each one have a named owner?

2. When a vendor you connected is breached, how many minutes until you can revoke their access?

3. Which of your sign-offs (attestations, justifications, ticket numbers) is checked by anything other than a person reading it?

4. Are secrets hidden by pattern only, and what is the secret that no pattern matches?

5. If you switch one control off, does anything tell you? If not, is another control covering it, or nothing?

Appendix A: case index

Guess result: M means my guess matched, W means it was wrong.

ID	Case	Group	Guess
N-R14-01	Inventory misses a source	Discover	M
N-R14-03	Long-lived CI variable read by another job	Front door and trust	M
N-R14-04	Certificate with no owner expires	Credentials	M
N-R14-05	Old OAuth grant, vendor breached	Credentials	M
N-R14-09	Identity with no owner	Own and retire	M
N-R14-11	Application retired, identities remain	Own and retire	M
N-R14-14	Rotation fails silently	Credentials	M
N-R14-15	Rotate before consumer is updated	Credentials	M
N-R14-17	Loose federation trust	Front door and trust	M
N-R14-18	Front door for new identities	Front door and trust	M
P-R15-02	Just-in-time window	Privileged access	M
P-R15-03	Work runs past the window	Privileged access	M
P-R15-05	Standing admin group membership	Privileged access	M
P-R15-07	Direct login still open	Privileged access	M
P-R15-08	Recording gap on one target	Privileged access	M
P-R15-09	Two approvers for Tier 0	Privileged access	M
P-R15-11	Break-glass used at 2 a.m.	Privileged access	M
P-R15-13	Break-glass becomes a side door	Privileged access	M
P-R15-17	Vendor session	Privileged access	M
P-R15-18	Vendor person leaves the vendor	Privileged access	M
S-R17-01	Personal OAuth grant to an AI tool	Shadow AI	M
S-R17-03	Agent runs under a person's account	Shadow AI	M
S-R17-04	Ghost credential	Shadow AI	M
S-R17-05	Secrets in AI-assisted code and config	Shadow AI	W
N-R14-23	Vendor breached, OAuth refresh token still valid	Gap cases from 2026 incidents	M
N-R14-24	Secrets in env variables not marked sensitive	Gap cases from 2026 incidents	M
N-R14-25	Credential stolen from a CI runner, replayed	Gap cases from 2026 incidents	W

Appendix B: how to re-run the lab

You need Python 3 and nothing else. The lab files are at roshantrivedi.co.in/nhi-lab/evidence/.

1. Download `cases.py`, `run.py` and the three guess files into one folder.
2. Run `python3 run.py`.
3. The runner first checks the SHA-256 of each guess file against the hash recorded at commit time, and stops if one differs.
4. It runs each case without and with the control, then switches each control off alone, and writes `RESULTS.md` and `results.json`.

Every secret in the cases is made up. Never paste a real secret into any test.

Appendix C: sources

OWASP Non-Human Identities Top 10 (2025). Ten named risks, including improper offboarding and human use of non-human identities.
OWASP Top 10 for Agentic Applications (2026). I read a summary by Teleport; check the OWASP original before quoting.
Tuhin Banerjee, Cloud Security Alliance blog, 23 April 2026. An opinion piece built on named incidents.
Vercel security incident, April 2026. Read through a summary by Strapi; attribution and some details are unverified.
GitGuardian State of Secrets Sprawl 2026. Vendor research, 2025 data.
NIST NCCoE concept paper on software and AI agent identity and authorization, 5 February 2026. A concept paper only.
Wiz blog, Non-Human Identities dashboard, February 2024; Clutch Security via Okta integrations page; SailPoint Entro documentation. Vendor descriptions, not tested.

Glossary

Non-human identity (NHI)	An account or credential used by software, not a person: a service account, API key, token, certificate or bot.
Service account	A directory or cloud account that an application uses to sign in.
Secret	A password, key or token that proves identity. Anyone who holds it can act as the identity.
Rotation	Replacing a secret with a new one on a schedule or after a leak.
Refresh token	A long-lived token that lets an app get new short-lived access without asking the person again.
OAuth grant	The permission a person gives an app to act on their behalf.
Allowlist	A list of apps or actions that are permitted. Anything not on it is refused.
Revoke	End a credential or grant so it no longer works.
Break-glass account	A powerful emergency account kept for incidents. Its use should be rare and always noticed.
PAM	Privileged access management: control, time-limiting and recording of powerful access.
IGA	Identity governance and administration: owners, reviews, and joining, moving and leaving.
JIT access	Just-in-time access: given for a short window and removed after.
CI/CD	The automated build and deploy pipeline, whose jobs hold credentials.
Control-off check	Switching one control off alone to see whether anything notices. If nothing does, another control was covering it, or the control did nothing.
Masked control	A control whose effect is hidden because another control already stopped the attack.
SHA-256	A fingerprint of a file. If the file changes, the fingerprint changes. It proves the guesses were not edited later.
Shadow AI	AI tools and agents that people connect to work systems without the company knowing.

About the author

Roshan Trivedi works in identity and privileged access security in Bengaluru, India. He writes and tests work on AI governance, MCP security, non-human identity and privileged access, and publishes the tests with the mistakes.

Website: roshantrivedi.co.in
Newsletter: buttondown.com/trivedi
Other labs: AI governance lab (13 rounds, 164 cases) and the MCP lab.

If you think a case is wrong, tell me. I will add it and keep the original.

Second run: 13 stretch cases and 6 chain tests

These ran after the first 27, with the same method. The guesses were committed first (commit 78d7e3e). The chain tests are rule models: I decided which control stops which link, so the results follow from my rules and are weak evidence.

Three guesses were wrong. I wrote that 9 identities with two or three names each would give 51 entries. That is impossible: it gives 43. After merging I expected 30 and got 29, because stripping trailing digits merged two real accounts into one. For the forgotten service account chain I guessed the secret scan on tickets was the most useful single control. In my rules the owner check stops it earliest, but only for accounts created after the rule. For an account that already exists the scan is the one that works.

My first run of the matching case was wrong because of my own test data. I had given 21 identities the same owner, so they merged into 11. I fixed the data and kept the first output.

Controls that hid each other. In the help-desk reset case, strong proof and the notice with a delay each stopped both attacker resets alone, so switching either off showed nothing. Rotating AI-service keys every 90 days changed nothing once the scan revoked the keys it could see.

Limits. A password copied during a checkout and used from another tool is not seen. If the real person approves the reset notice, the account is lost with both controls on. An extension of an automation is accepted on any written reason.

Evidence you can check

The guess files, the code and the results are public at roshantrivedi.co.in/nhi-lab/. The SHA-256 hash of each guess file was recorded when I committed it, before the code existed.

Guess file	SHA-256
Rounds 14 and 15 (20 cases)	`f06f355eb80c151cb237ca4ef0c09dad9bc995fe5d395dca03f8756b0c69c784`
Round 17, shadow AI (4 cases)	`4e6dfc1a80b2fa1e0a0da0a129882e87fdd3be931b5dddafd018d92c05dc8b7c`
Gap cases (3 cases)	`7d3aee7a941b3915915690294e97ef22118957fc82b5505a1a0502d6e4bd5f8d`
Stretch and chain tests (19 cases)	`40c2f87c9f3fa914b48a09c4abf016f1189b02ea91f07232e456275b842489ed`

If you think a case is wrong or can think of a variant that breaks a control, tell me. I will add it and keep the original on the page. Subscribe: buttondown.com/trivedi